IT Security and Access Standard

Current requirements for devices, identities, remote access, and privileged administration

Owner	Cybersecurity	**Version**	2.0
Effective	01 Jul 2026	**Classification**	Internal

1. Purpose and scope

This standard applies to employees, contractors, managed devices, and administrators who access Contoso Systems information resources.

1.1 Security objectives

- Protect company data on laptops and mobile devices.
- Reduce account compromise through strong authentication.
- Apply least privilege and record privileged activity.
- Provide clear controls that can be verified through audit evidence.

1.2 Core device controls

Control ID	Requirement	Evidence
DEV-01	Use a 12-character password and multifactor authentication.	Identity sign-in record
DEV-02	Enable full-disk encryption on managed laptops.	Device compliance record
DEV-03	Install critical security updates within 7 calendar days.	Patch report
DEV-04	Lock the screen after 10 minutes of inactivity.	Device policy

Current version: This version replaces SEC-114 version 1.0. Search solutions should filter Status = Current.

2. Identity and remote access

Access decisions must combine user identity, device condition, resource sensitivity, and business need.

2.1 Authentication

Multifactor authentication is mandatory for email, collaboration services, remote access, and administrator portals. Password-only access is not permitted for privileged roles.

2.2 Remote access

- Use the approved secure access client from a compliant device.
- Contractors may access only the assigned project workspace.
- Do not download Restricted data to unmanaged devices.
- Report unexpected authentication prompts to the Service Desk within 30 minutes.

2.3 Access matrix

Role	Allowed resources	Review cycle
Employee	Internal apps and assigned data	Quarterly
Contractor	Assigned project workspace	Monthly
Administrator	Approved admin tools	Monthly
Security analyst	Security operations data	Quarterly

Exception path: Exceptions require the system owner and Cybersecurity approver, an expiry date, and a compensating control.

3. Monitoring, incidents, and compliance

Controls are effective only when failures are detected, recorded, and corrected.

3.1 Monitoring requirements

- Retain identity and device compliance logs for 180 days.
- Alert on repeated failed multifactor authentication and impossible travel.
- Review privileged role assignments every month.
- Record policy exceptions in the governance register.

3.2 Incident response

If credentials may be exposed, reset the password, revoke active sessions, confirm multifactor authentication status, and assess whether Restricted data was accessed.

3.3 Compliance checks

Check	Target	Owner
Managed-device compliance	At least 98%	Endpoint Operations
Critical patch within 7 days	At least 95%	Infrastructure
Monthly admin review	100% complete	Identity Team

RAG test ideas: Ask for exact control IDs, contractor rules, current password length, exception workflow, and evidence requirements.